Buổi 3 – Nguyên tắc thiết kế API & Best Practices

Đào Minh Tuấn - 2401165

1. Naming & nguyên tắc cốt lõi

- Consistency > Cleverness: ưu tiên nhất quán, dễ hiểu
- URL biểu diễn tài nguyên, HTTP Method biểu diễn hành động
  + Đúng: GET /users/123
  + Sai: /getUser?id=123
- Quy tắc:
  + URL viết lowercase
  + Path dùng kebab-case, query dùng snake_case.
  + Collection dùng số nhiều: /users, /orders.
  + Không dùng động từ trong URL.
  + Không dùng .json; dùng Accept header
  + Quan hệ cha-con: /users/{id}/orders

2. Cấu trúc Endpoint.

- Collection: GET /users, POST /users.
- Item: GET/PATCH/DELETE /users/{id}.
- Sub-resource: /users/{id}/orders.
- Nesting nên ≤ 3 cấp. Quá sâu → flatten:
  + /tasks?project_id=123.

3. HTTP Methods

- Safe: GET, HEAD, OPTIONS → k° thay đổi dữ liệu.
- Idempotent: GET, PUT, DELETE → gọi nhiều lần vẫn cùng trạng thái
- PUT: thay toàn bộ tài nguyên.
- PATCH: sửa một phần.
- POST: tạo mới, thường không idempotent
- Retry POST có thể tạo trùng → dùng Idempotency-Key

4. HTTP Status Codes

-Thành công:

+200 OK: thành công, có body

+201 Created: tạo mới, nên có Location

+204 No Content: thành công, không body.

+ 304 Not Modified dùng lại cache
- Client Error:
+ 400: request / JSON sai
+ 401: chưa xác thực / token hết hạn
+ 403: đã xác thực nhưng không có quyền
+ 404: không tìm thấy
+ 409: xung đột dữ liệu
+ 422: dữ liệu đúng cú pháp nhưng sai nghiệp vụ
+ 429: quá nhiều request, thường có Retry-After
- Server Error:
+ 500: lỗi nội bộ server.
+ 503: server quá tải / bảo trì

Problem Details - RFC 7807/9457:
+ type, title, status, detail, instance

5. Pagination & Query
- Offset: ? page = 2 & per_page = 50.
+ Dễ dùng nhưng chậm khi dữ liệu lớn, dễ trôi dữ liệu
- Cursor: ? limit = 50 & cursor = ...
+ Nhanh, ổn định, khó nhảy đến trang bất kỳ
- keyset: ? after_id = 1000
+ Hiệu năng cao, tận dụng index.

Query phổ biến: - Filter: ? status = active
- Sort: ? sort = -created_at
- Chọn field: ? field = id, name, price

6. Anti-patterns cần tránh.
1. Động từ trong URL: /createUser
2. Lỗi nhưng vẫn trả 200 OK.
3. Naming không thống nhất
4. Lẫn số ít / số nhiều
5. Đưa API key/token vào query URL
6. Thêm .json vào endpoint
7. Lộ ID database nội bộ → nên dùng UUID / ULID.
8. Ép JSON, bỏ qua Content Negotiation